

Auditoria de segurança

067-android-native-engineering - 18/09/2026

Resultado

Nenhum achado de segurança confirmado permanece em aberto nesta Change.

Escopo

Skill local, metadados YAML, referências Markdown, validador Python somente leitura e artefatos Spec Driven da Change. Não há aplicativo Android, API, frontend, autenticação, banco de dados, deploy ou integração com segredos.

Superfície e método

A auditoria inspecionou a entrada de caminho do validador, operações de arquivos, diagnósticos, dependências, metadados, links, padrões de segredo, APIs Python perigosas e artefatos gerados. Também distinguiu categorias não aplicáveis de controles efetivamente verificados.

Conclusões

Entrada e injeção: conforme no escopo. O caminho é resolvido e usado apenas em operações locais de leitura; não é interpolado em shell, SQL, HTML ou código dinâmico.

Segredos: nenhuma atribuição semelhante a senha, segredo, chave ou token foi encontrada nos artefatos atuais. Os caminhos novos ainda não possuem histórico Git. Correspondências históricas em outros caminhos ficaram fora do escopo e nenhum valor foi exposto no relatório.

Dependências: o validador usa somente a biblioteca padrão Python. Não foram encontradas chamadas a subprocess, execução dinâmica, desserialização insegura, rede ou escrita no projeto analisado.

Autenticação, autorização, tenant, IDOR, XSS, persistência e deploy: não aplicáveis porque essas superfícies não existem nesta Change.

Controle preventivo Android

A skill proíbe registrar tokens, credenciais, PAN, localização precisa e dados pessoais. O validador reprova a presença de local.properties, e aplicações consumidoras devem revisar Manifest, Intents, permissões, armazenamento, backup e rede conforme sua superfície real.

Limitações

A análise é estática e delimitada à Change. Não existe aplicativo consumidor para testar permissões, componentes, rede ou comportamento em dispositivo. Ausência de achados neste escopo não prova a segurança de aplicações futuras.

Recomendações

P3 - manter o validador somente leitura e sem comandos derivados da entrada. P3 - repetir auditoria contextual em cada aplicação consumidora. P3 - manter artefatos gerados, local.properties e credenciais fora do versionamento.

Evidências

Busca de segredos atuais: nenhuma correspondência. Busca de APIs Python perigosas: nenhuma correspondência. Reparse points: nenhum. O bytecode .pyc produzido pela validação foi removido antes do commit e pode ser regenerado.